Security assessment - IT Support Homelab

Authorization: all targets are my own homelab; testing performed by the owner, Nazmul Hassan.

Owner-authorized local learning and assessment. No third-party engagement.

Baseline: 20261017T034611Z-baseline. Latest assessment: 20261017T133728Z-retest (UTC timestamps).

Executive summary

3 confirmed findings: 1 Medium, 2 Low, 0 High, 0 Critical. 3 fixed and retested; 0 open or unverified. 5 service hosts inventoried. The latest unauthenticated Nuclei pass produced 20 informational template matches; these are observations, not automatically confirmed vulnerabilities.

Scope and rules of engagement

Only current Compose containers labelled project it-support-homelab and services fileserver, directory, printserver, wireguard, uptime on office-lan 172.20.0.0/16, plus 127.0.0.1 ports 1445, 1389, 1636, 51821, 13001, 6631. Discovery uses their exact inspected addresses, never a /16 sweep. Homepage is supporting infrastructure, not scanned. The local TLS proxy is a remediation control and is checked through the same loopback ports. No internet/third-party targets, live cracking, destructive exploits or denial of service. Only fictional users alice, bob, carol and a temporary assessment_probe are used. The scanner has no Docker socket or credentials; IPv4 egress is limited to the five lab addresses, IPv6 is blocked. Redirects, external NSE categories, OAST and scanner updates are disabled. Tool installation may download public packages.

Methodology and severity

1. Validate Compose labels, network membership, addresses and loopback bindings.
2. Nmap host discovery and top-1000 TCP connect/version discovery, using default AND safe NSE scripts with dangerous/external categories excluded.
3. Nuclei v3.11.1 with four pinned community HTTP GET templates, two requests/second, no redirects or OAST.
4. Authenticated Samba access/ACL and AD policy/group/ACL checks; credential-quality review; admin transport/auth checks.
5. Manually supervised minimal proofs, persistent remediation, and repeat checks.
6. Preserve raw output and SHA-256 manifests; normalize to JSON/Markdown and generate this PDF.

Ratings are CVSS-style qualitative priorities, adjusted for actual access prerequisites and impact. No numeric score is invented. Critical/High require demonstrated substantial impact; Medium has a credible adjacent-network integrity/confidentiality risk; Low covers constrained policy/transport weaknesses; Informational observations are not counted as vulnerabilities. Scanner suggestions require analyst review.

Findings register

ID	Severity	Finding	Status
SAL-01	Medium	SMB signing is optional	Fixed - retested
SAL-02	Low	Zero minimum password age permits rapid password changes	Fixed - retested
SAL-03	Low	Administration uses plaintext HTTP	Fixed - retested

SAL-01 - SMB signing is optional

Medium | Fixed - retested | fileserver / SMB 445

A malicious peer on office-lan could tamper with unsigned SMB sessions or participate in relay attacks. Requires access to this local lab network; no internet exposure was observed.

CVSS-style qualitative Medium: adjacent-network prerequisite, potential confidentiality/integrity impact. No exploit chain or numeric CVSS score asserted.

Manual verification: Compare the baseline Nmap smb2-security-mode (enabled but not required) with a direct SMB2 NEGOTIATE response on host loopback 1445 and the retest Nmap output (required). Confirm alice can still list Finance with signing required. In this Samba client, signing=disabled remains a preference and does not force an unsigned session when the server requires signing; its exit code is not a closure criterion.

Observed protocol evidence: baseline: 311:
Message signing enabled but not required; latest: 311:
Message signing enabled and required. Independent loopback SMB2 required bit: True; SecurityMode: 3.

Baseline raw proof and retest raw proof.

Remediation: Set server signing = mandatory in the persistent fileserver Compose command; recreate the service and require signed client sessions.

Before: control passed = False. **After:** control passed = True.

SAL-02 - Zero minimum password age permits rapid password changes

Low | Fixed - retested | directory / ITOPS.LAB

An authenticated fictional user can change passwords repeatedly, reducing the value of the 12-password history. No weak password or completed history bypass is claimed.

CVSS-style qualitative Low: requires a valid local domain account; policy weakness without demonstrated compromise.

Manual verification: Create one temporary fictional assessment_probe account with random strong passwords. Perform two self-service changes, then remove the account in finally. Retest must reject an immediate self-service change.

Observed account proof: baseline: SELF_CHANGE_RC=0; SELF_CHANGE_RC=0; RAPID_CHANGES_ALLOWED=true. Latest: SELF_CHANGE_RC=255; RAPID_CHANGES_ALLOWED=false. Temporary account deletion is confirmed in each raw log.

Baseline raw proof and retest raw proof.

Remediation: Set minimum password age to one day in seed.sh and the running directory; preserve administrative password-reset workflows.

Before: control passed = False. **After:** control passed = True.

SAL-03 - Administration uses plaintext HTTP

Low | Fixed - retested | wg-easy, Uptime Kuma, CUPS / host loopback

Admin sessions and CUPS Basic credentials lack transport encryption on the host-facing HTTP listeners. Loopback binding substantially reduces exposure; privileged host compromise is outside this proof.

CVSS-style qualitative Low in this loopback-only deployment. Three endpoints are grouped under one root cause; not three inflated findings.

Manual verification: Make credential-free HTTP requests to all three original ports before remediation, then verify HTTP no longer serves the application and HTTPS validates against the exported lab CA.

Observed transport proof:

Before: http://127.0.0.1:51821/ => 200; http://127.0.0.1:13001/ => 302; http://127.0.0.1:6631/admin/ => 401.

After: http://127.0.0.1:51821/ => 400; http://127.0.0.1:13001/ => 400; http://127.0.0.1:6631/admin/ => 400; https://127.0.0.1:51821/ => 200; https://127.0.0.1:13001/ => 302; https://127.0.0.1:6631/admin/ => 401.

Baseline raw proof and retest raw proof.

Remediation: Terminate TLS with a local Caddy CA on the same loopback admin ports and remove direct HTTP host publications. Trust the exported public CA explicitly. Internal office-lan HTTP remains a documented residual risk.

Before: control passed = False. **After:** control passed = True.

Positive controls and analyst interpretation

Finance access must deny bob while permitting alice; guest access is tested independently for Public, Finance and Scans. Company-wide authenticated Public access is intentional, not a world-readable vulnerability. AD complexity, history, lockout settings, privileged group membership and raw domain/OU SDDL are preserved for review. An ACL listing alone is not an exhaustive effective-permission analysis. CUPS anonymous /admin returns an authentication challenge. wg-easy and Kuma login panels do not by themselves prove auth bypass. No successful default-password login or anonymous administrative change is claimed.

Remediation, rollback and residual risk

See change record and manual procedure. Changes are persisted in the homelab Compose/configuration files, not just running containers. Rerun from a clean clone after starting the homelab. The local CA public certificate is safe to publish; its private key stays in a Docker volume. Do not install this learning-lab CA globally unless you understand that trust decision. The client checks use an explicit CA file. Template header observations and internal HTTP remain follow-up hardening opportunities; closed findings have the limited closure criteria stated above.

Honest limits

Owner-performed assessment of five local Docker services and fixed loopback ports. Top 1,000 TCP ports plus the known wg-easy admin port; no UDP sweep, external targets, denial of service, destructive exploits, password cracking, full CVE coverage, AD attack paths, Windows domain join, GPO or production monitoring. Known tools and four reviewed Nuclei templates. No assertion of paid penetration-testing, OSCP-level exploitation or production SOC/incident-response experience. Privileged Docker operators can access credentials and bypass controls. The proxy encrypts host-facing admin access; HTTP on the isolated office-lan remains a residual risk. Default-password checks review only the fictional credentials in the local ignored .env; no dictionary guessing. Observed image tags/versions do not prove current patch status. No unsupported CVE claims are made.

Version review and follow-up

Runtime checks (failed commands remain explicitly unknown):

- wireguard: 1.0.1
- uptime: 1.23.17
- fileserver: Version 4.12.2
- directory: Version 4.17.12-Debian
- printserver: 2.4.18-1

The baseline Nmap guessed Samba 4.6.2; the runtime file-server check reported 4.12.2. Prefer runtime/package evidence over fingerprints. The wg-easy image track is 14; its internal package.json version is not a release-track version. Official references checked on 17 October 2026 were wg-easy v15.4.0, Uptime Kuma 2.5.6 and CUPS v2.4.20. The baseline ran older release tracks; schedule compatibility, migration and security-advisory review. Reference metadata is dated, not refreshed by local scanning. No version-only CVE finding or assumption about distribution backports is made. No major-version upgrade was performed in the three remediation loops. Official release metadata; runtime-versions.json is linked in the raw index.

Appendix A - asset inventory

Asset	IP	TCP port	Service	Version
directory	172.20.0.5	53	domain	generic dns response: NOTIMP
directory	172.20.0.5	88	kerberos-sec	server time: 2026-10-17 13:38:42Z
directory	172.20.0.5	135	msrpc	Microsoft Windows RPC
directory	172.20.0.5	139	netbios-ssn	Samba smbd 4.6.2
directory	172.20.0.5	389	ldap	Anonymous bind OK
directory	172.20.0.5	445	netbios-ssn	Samba smbd 4.6.2
directory	172.20.0.5	464	kpasswd5	
directory	172.20.0.5	636	ldap	Anonymous bind OK
directory	172.20.0.5	3268	ldap	Anonymous bind OK
directory	172.20.0.5	3269	ldap	Anonymous bind OK
directory	172.20.0.5	49152	unknown	
directory	172.20.0.5	49153	unknown	
directory	172.20.0.5	49154	unknown	
fileserver	172.20.0.7	139	netbios-ssn	Samba smbd 4.6.2
fileserver	172.20.0.7	445	netbios-ssn	Samba smbd 4.6.2
printserver	172.20.0.2	631	ipp	CUPS 2.4
uptime	172.20.0.4	3001	nessus	
wireguard	172.20.0.3	51821	unknown	

Appendix B - scanner observations

- wg-easy-panel / info: http://172.20.0.3:51821
- http-missing-security-headers / info: http://172.20.0.2:631
- http-missing-security-headers / info: http://172.20.0.2:631
- http-missing-security-headers / info: http://172.20.0.2:631
- http-missing-security-headers / info: http://172.20.0.2:631
- http-missing-security-headers / info: http://172.20.0.2:631
- http-missing-security-headers / info: http://172.20.0.2:631
- http-missing-security-headers / info: http://172.20.0.2:631
- http-missing-security-headers / info: http://172.20.0.2:631
- http-missing-security-headers / info: http://172.20.0.3:51821
- http-missing-security-headers / info: http://172.20.0.3:51821
- http-missing-security-headers / info: http://172.20.0.3:51821
- http-missing-security-headers / info: http://172.20.0.3:51821
- http-missing-security-headers / info: http://172.20.0.3:51821
- http-missing-security-headers / info: http://172.20.0.3:51821
- http-missing-security-headers / info: http://172.20.0.3:51821
- http-missing-security-headers / info: http://172.20.0.3:51821
- http-missing-security-headers / info: http://172.20.0.3:51821
- http-missing-security-headers / info: http://172.20.0.3:51821
- uptime-kuma-panel / info: http://172.20.0.4:3001/dashboard

Appendix C - raw evidence index

- baseline/ad-groups-acls.txt
- baseline/ad-manual.txt
- baseline/ad-policy.txt
- baseline/checks.json
- baseline/credential-quality.json
- baseline/discovery-console.txt
- baseline/discovery.gnmap
- baseline/discovery.nmap
- baseline/discovery.xml
- baseline/firewall.txt
- baseline/http-manual.json
- baseline/images.json
- baseline/inventory.json
- baseline/inventory.md
- baseline/loopback-inventory.json
- baseline/nmap-version.txt
- baseline/nuclei-console.txt
- baseline/nuclei-normalized.json
- baseline/nuclei-version.txt
- baseline/nuclei.jsonl
- baseline/scanner.txt
- baseline/scope.json
- baseline/services-console.txt
- baseline/services.gnmap
- baseline/services.nmap
- baseline/services.xml
- baseline/sha256.json
- baseline/smb-manual.txt
- baseline/urls.txt
- baseline/wg-admin-console.txt
- baseline/wg-admin.gnmap
- baseline/wg-admin.nmap
- baseline/wg-admin.xml
- latest/ad-groups-acls.txt
- latest/ad-manual.txt
- latest/ad-policy.txt
- latest/admin-auth.json
- latest/checks.json
- latest/credential-quality.json
- latest/discovery-console.txt
- latest/discovery.gnmap
- latest/discovery.nmap
- latest/discovery.xml
- latest/firewall.txt
- latest/http-manual.json
- latest/images.json
- latest/inventory.json
- latest/inventory.md
- latest/loopback-inventory.json
- latest/nmap-version.txt
- latest/nuclei-console.txt
- latest/nuclei-normalized.json
- latest/nuclei-version.txt
- latest/nuclei.jsonl
- latest/runtime-versions.json

- latest/scanner.txt
- latest/scope.json
- latest/services-console.txt
- latest/services.gnmap
- latest/services.nmap
- latest/services.xml
- latest/sha256.json
- latest/smb-manual.txt
- latest/smb-negotiate.json
- latest/urls.txt
- latest/wg-admin-console.txt
- latest/wg-admin.gnmap
- latest/wg-admin.nmap
- latest/wg-admin.xml

Raw Nmap XML/normal/grepable output, Nuclei JSONL, service proofs and SHA-256 manifests are linked above. These logs are collected at source without credential values, cookies, tokens or complete Docker inspect output.

References

- Nmap NSE categories
- Nuclei source and CLI
- Community templates pinned source
- Samba smb.conf
- Samba samba-tool
- Caddy internal TLS